



unidad **1**

Introducción a la seguridad informática

Ideas clave

INTRODUCCIÓN A LA SEGURIDAD INFORMÁTICA

Seguridad

- De la información
- Informática

Conceptos básicos

- Activos de una organización
- Vulnerabilidades
- Ataques
- Amenazas
- Riesgos
- Impactos
- Desastres

Principios de la seguridad

- Integridad
- Confidencialidad
- Disponibilidad
- Otros aspectos relacionados

Políticas de seguridad

Planes de contingencia

1. Seguridad informática y seguridad de la información

- ✓ Uno de los activos más valiosos para cualquier empresa es la información que maneja.
- ✓ La información es el conjunto de datos que da sentido a una empresa.
- ✓ Este concepto de seguridad puede entenderse desde dos puntos de vista:
 - ✓ Seguridad de la información
 - ✓ Seguridad informática

Seguridad de la información

Es el conjunto de medidas y procedimientos, tanto humanos como técnicos, que permiten proteger la integridad, confidencialidad y disponibilidad de la información.

Integridad → certifica que información y su procesamiento son exactos y completos

Confidencialidad → Acceso a usuarios autorizados

Disponibilidad → información disponible a demanda

Engloba medidas de seguridad que afectan a la información independientemente del tipo de esta, soporte en el que se almacene, forma en que se transmita, etc.

Seguridad informática

Es una rama de la seguridad de la información que trata de proteger la información que utiliza una infraestructura informática y de telecomunicaciones para ser almacenada o transmitida.

Clasificación en función de lo que se quiere proteger:

- **SEGURIDAD FÍSICA:** protección física del sistema ante amenazas
- **SEGURIDAD LÓGICA:** protección de datos, aplicaciones, sistemas operativos

Clasificación en función del momento en que ocurre la protección:

- **SEGURIDAD ACTIVA:** prevenir, detectar y evitar incidente antes de que se produzca. Ej.: contraseñas
- **SEGURIDAD PASIVA:** técnicas para minimizar consecuencias de incidente de seguridad. Ej.: copias de seguridad.

2. Conceptos básicos

Activos

- ✓ **Recursos del sistema** (informático o no) **necesarios** para que la organización alcance los objetivos propuestos; es decir, todo aquello que tenga valor y que **deba ser protegido** frente a un eventual percance, ya sea intencionado o no.
- ✓ **La seguridad informática tiene como objetivo proteger dichos activos.**
- ✓ Principales activos de una empresa son:
 - ✓ la información
 - ✓ el software
 - ✓ la infraestructura tecnológica
 - ✓ el personal que utilice esta infraestructura.

2. Conceptos básicos

Vulnerabilidades

- ✓ Se trata de cualquier **debilidad** de un activo que pueda repercutir de alguna forma sobre el correcto funcionamiento del sistema informático → “agujeros de seguridad”
- ✓ Es **muy importante corregir** cualquier vulnerabilidad detectada, porque constituye un peligro potencial para el sistema en general.
- ✓ Para minimizarlas, los administradores de los sistemas informáticos deben revisar periódicamente el sistema, mantenerse informados en temas relacionados con la seguridad de los sistemas que administran, etc.

Conceptos básicos

Amenazas

Son cualquier **entidad o circunstancia que atente contra el buen funcionamiento** de un sistema informático.

En función de las acciones realizadas por el atacante se dividen en:

Amenazas pasivas (escuchas) → su objetivo es obtener información relativa a una comunicación.

Amenazas activas → tratan de realizar algún cambio no autorizado en el estado del sistema.



Conceptos básicos

Ataques

- ✓ **Son acciones que tratan de aprovechar una vulnerabilidad de un sistema informático** para provocar un impacto sobre él e incluso tomar el control del mismo.
- ✓ Acciones tanto intencionadas como fortuitas.
- ✓ Normalmente un **ataque informático** pasa por las siguientes **fases**:
 - ✓ Reconocimiento → información sobre la víctima
 - ✓ Exploración → información sobre el sistema a atacar
 - ✓ Obtención de acceso → explotación de vulnerabilidad
 - ✓ Mantenimiento del acceso
 - ✓ Borrar las huellas del ataque.

Ingeniería social

Conceptos básicos

Riesgos

- ✓ Es la estimación del **grado de exposición** a que una **amenaza** se materialice sobre uno o más activos causando daños o perjuicios a la organización.
- ✓ Es la probabilidad de que una amenaza se materialice **aprovechando una vulnerabilidad** y causando daño (impacto) en un proceso o sistema.
- ✓ Se trata de una medida de la probabilidad de que se materialice una amenaza.
- ✓ En el **ANÁLISIS DE RIESGOS** hay que tener en cuenta qué activos hay que proteger, sus vulnerabilidades, amenazas, su probabilidad y su impacto. → TIEMPO, ESFUERZO, DINERO



Conceptos básicos

Impacto

- ✓ Una organización se ve afectada cuando se produce una situación que atenta contra su funcionamiento normal.
- ✓ El impacto sería el **alcance producido o daño causado en caso de que una amenaza se materialice**.
- ✓ Hay que **identificar** los impactos para la organización en el caso de que se produzcan las amenazas



Conceptos básicos

Desastres

Un desastre es cualquier evento accidental, natural o malintencionado que interrumpe las operaciones o servicios habituales de una organización.

Puede destruir los activos de la empresa, tanto físicos como lógicos, por lo que podría ocasionar grandes pérdidas e incluso el cese de la actividad económica.

Las organizaciones deben estar preparadas ante cualquier tipo de desastre de manera que se reduzca el impacto que pueda ocasionar
→ PLANES DE CONTINGENCIA



3. Principios de seguridad informática

Aunque no existe ningún sistema totalmente seguro e infalible al 100%, para considerar seguro un sistema se debe garantizar que se cumplen los requisitos básicos de seguridad informática:

- Integridad
- Confidencialidad
- Disponibilidad
- Otras:
 - No repudio
 - Autenticación



3. Principios de seguridad informática

Integridad

- ✓ Consiste en garantizar que **la información solo pueda ser alterada por las personas autorizadas** o usuarios legítimos, independientemente de su intencionalidad.
- ✓ La vulneración de la integridad tiene distinto significado según se produzca en un equipo o en una red de comunicaciones
 - ✓ Equipo de trabajo: un usuario no legítimo modifica información del sistema sin autorización.
 - ✓ Red de comunicaciones: el atacante actúa como intermediario (ataques man-in-the-middle). Solución: firma electrónica.



3. Principios de seguridad informática

Confidencialidad

- ✓ Garantiza que la **información solo es accesible e interpretada por personas o sistemas autorizados.**
- ✓ La vulneración de la confidencialidad también afecta de forma diferente a equipos y redes:
 - ✓ Equipo de trabajo: un atacante accede a un equipo sin autorización, controlando sus recursos
 - ✓ Red de comunicaciones: un atacante accede a los mensajes que circulan por ella sin tener autorización. Solución: cifrado de la información, protocolos seguros,...

TOP
SECRET

3. Principios de seguridad informática

Disponibilidad

- ✓ Asegurar que la información es accesible en el momento adecuado para los usuarios legítimos.
- ✓ La vulneración de la disponibilidad también afecta de forma diferente a equipos y redes:
 - ✓ Equipo de trabajo: los usuarios autorizados no pueden acceder a él.
 - ✓ Red de comunicaciones: un recurso de red deja de estar disponible. Ejemplo: ataques de denegación del servicio.



Principios de la seguridad

Otras características de un sistema seguro

NO REPUDIO: Probar la participación ambas partes en una comunicación. 2 clases:

- No repudio en origen: protege al destinatario del envío, ya que este recibe una prueba de que el emisor es quien dice ser.
- No repudio de destino: protege al emisor del envío, ya que el destinatario no puede negar haber recibido el mensaje del emisor.

AUTENTICACIÓN: Permite comprobar la identidad de los participantes en una comunicación y garantizar que son quienes dicen ser.

4. Políticas de seguridad

- ✓ Se trata de una declaración de intenciones de alto nivel que cubre la seguridad de los sistemas informáticos y que proporciona las bases para definir y delimitar responsabilidades para las diversas actuaciones técnicas y organizativas que se requieran.
- ✓ Objetivo: **concienciar** a los miembros de una organización sobre la importancia y sensibilidad de la información y servicios críticos.
- ✓ Se puede decir que son una **descripción de todo aquello que se quiere proteger**.

Aspectos a tener en cuenta:

- ✓ Elaborar las reglas y procedimientos para los servicios críticos.
- ✓ Definir las acciones a ejecutar y el personal involucrado.
- ✓ Sensibilizar al personal del departamento encargado de la administración del sistema informático de los posibles problemas relacionados con la seguridad que pueden producirse.
- ✓ Establecer una clasificación de los activos a proteger en función de su nivel de criticidad.

5. Planes de contingencia

Las políticas de seguridad contemplan la parte de prevención de un sistema, pero **no hay que desechar la posibilidad de** que, aun a pesar de las medidas tomadas, pueda ocasionarse un **desastre**. Ningún sistema es completamente seguro. Es en este caso cuando entran en juego los planes de contingencia.

El **plan de contingencia** contiene medidas detalladas para conseguir la recuperación del sistema, es decir, creadas para ser utilizadas cuando el sistema falle. Su creación debe abarcar las siguientes fases:

- ✓ **Evaluación:** identificación de elementos críticos, analizar impacto, soluciones alternativas a los problemas que puedan surgir.
- ✓ **Planificación:** documentar y validar plan de contingencia.
- ✓ **Realización de pruebas:** para comprobar viabilidad del plan
- ✓ **Ejecución del plan:** para comprobar su efectividad.
- ✓ **Recuperación:** restablecimiento del orden tras el incidente o ataque

5. Planes de contingencia

El plan de contingencia deberá ser **revisado** periódicamente para que siempre pueda estar de acuerdo con las necesidades de la organización.

Entre las numerosas **medidas** que debe recoger, podemos indicar:

- ✓ tener **redundancia**
- ✓ tener la **información** almacenada de manera **distribuida**
- ✓ tener un **plan de recuperación**
- ✓ tener al **personal formado y preparado**.